Concernant la détection des transfert de fichiers malveillants, on a souvent 2 approches une liste noire de commande spécifiques souvent facile à contourner, faut pas tomber dans le piège du whoami. Et une liste blanche beaucoup plus robuste qui n'autorise que les commandes légitimes.
Il y a aussi la détection par le User-Agent, mais elle est facilement contournable par un attaquant sophistiqué : Exemple : curl -A "User Agent Commun de Confiance", Powershell aussi à avec Invoke-WebRequest un paramètre -UserAgent qui permet de le modifier. ⚠ Rappellons que souvent Powershell ou Netcat sont dans les rejets de la liste blanche c'est là que les LOLBins deviennent indispensables.

Nous avons vus dans ce module certaines des nombreuse façon de transferez des fichiers entre machine d'attaques et machines victims. Maintenant il faut pratiquer a chaque fois tester une façon différente et prendre son temps dessus afin de la maitriser, prenons le temps aussi de tester des nouveau LOLBins ou GTFOBins.
C'est cette variété de techniques maitrisées qui nous rendrons = DANGEREUX ;)!



Shells & Payloads

Catégorie : ⚔ Offensive
Difficulté : Medium, Tier I
Durée Estimée : 3 days

Introduction :

Un shell est un programme qui fournit à un utilisateur une interface pour saisir des instructions dans le system et afficher les sorties texte. (Note : les shells CLI sont plus difficiles à repérer que GUI).
Dans l'ensemble de l'industrie informatique une charge utile (payload) est du code conçu dans l'intention d'exploiter une vulnérabilité sur un système informatique, ce terme désigne divers types de malwares, aussi bien les ransomwares - Dans ce module nous travaillerons avec de nombreux payloads et méthodes de livraison dans le but de nous donner accès à un hôte et d'établir des sessions de shell distant avec les systems vulnérable.
Emulateur de terminal : application graphique comme (mate, putty, iterm2) que nous utilisons pour interagir avec le shell
Interpreteur de ligne de commande : C'est le programme qui interprète les commandes que l'on tape et les transmet au système d'exploitation c'est ce qu'on apelle souvent le shell lui-même (Bash, Powershell).

• En pentest il est crucial de déterminer quel interpreteur de commande (shell) est utilisé sur un system cible cela peux se faire avec ps pour lister les procesus en cours ou env pour vérifier la variable d'environnement SHELL.

Shells de Connexion. BindShell :

Avec un shell de connexion un écouteur est démarré sur la cible et attend une connexion depuis la machine d'attaque. Exemple ci dessous.

